

Token Theft Playbook

Microsoft Learn field guide for token theft investigation, containment, and remediation

Condensed, non-verbatim operational guide

Purpose	Quick-reference guide for identifying, investigating, containing, remediating, and documenting token theft attacks in Microsoft Entra and Microsoft 365 environments.
Primary audience	Security analysts, incident responders, identity administrators, Microsoft Entra administrators, SecOps teams, and IT operations teams.
Reference source	https://learn.microsoft.com/en-us/security/operations/token-theft-playbook
Generated	2026-07-03
Use note	
This document is a condensed field guide based on Microsoft Learn guidance. Use the linked Microsoft Learn article as the authoritative source for the latest prerequisites, decision tree, investigation guidance, and product-specific details.	

Prepared for: Muataz Awad | Microsoft Security customer-facing readiness

1. Investigation objective and expected outcome

The investigation should determine whether a threat actor compromised and replayed tokens issued to a user or service principal, whether organizational resources were accessed by using the stolen token, and what containment and remediation actions are required to minimize further risk.

Why this matters

The Microsoft Learn playbook describes token theft as a scenario where threat actors compromise and replay tokens issued to a user, even after the user satisfied multifactor authentication; because authentication requirements are already met, the threat actor can access organizational resources using the stolen token.

2. At-a-glance workflow

Step	Phase	Focus
1	Confirm the token theft signal	Start from Microsoft Entra sign-in/audit logs, Identity Protection risk detections, Defender/Sentinel alerts, user reports, or suspicious resource access.
2	Identify affected identities	Determine whether the evidence involves user tokens, service principal tokens, or both; capture UPNs, service principal IDs, device context, IPs, applications, and resources accessed.
3	Correlate logs and resource activity	Use Microsoft Entra sign-in and audit logs, service principal logs, Unified Audit Log, advanced hunting, SIEM/Sentinel data, and Defender for Cloud Apps where available.
4	Contain active risk	Revoke access, invalidate sessions where supported, block or disable affected identities when needed, and isolate or investigate devices involved in token compromise.
5	Remediate root cause and persistence	Reset credentials where needed, review authentication methods, investigate devices, review app access, and remove persistence mechanisms.
6	Document and harden	Record timeline, indicators, affected identities/resources, containment actions, remediation, detection gaps, and recommended improvements.

3. Readiness prerequisites and recommendations

Required logs: Access to Microsoft Entra ID sign-in and audit logs for users and service principals.

Required role access: An account assigned one of these Microsoft Entra roles: Security Administrator, Security Reader, Global Reader, or Security Operator.

Advanced hunting: Recommended: enable advanced hunting and have access to the last seven days of event data.

Defender for Cloud Apps: Recommended: connect Office 365 to Microsoft Defender for Cloud Apps using the app connector API.

Unified Audit Log: Recommended: access the Unified Audit Log for additional signals.

Risk detections: Recommended: use Microsoft Entra ID premium risk detections in Microsoft Entra ID P2 and E5 for more granular investigation triggers and instruction.

Authentication architecture: Recommended: use managed authentication with password hash synchronization rather than federated authentication to access additional signals.

SIEM/Sentinel: Requirement area: configure a SIEM such as Microsoft Sentinel for centralized log visibility, including sign-in logs, audit logs, risk events, and relevant alerts.

Source alignment

These readiness items are taken from the Microsoft Learn prerequisites, recommendations, and requirements sections in the token theft playbook. Validate licensing, connectors, and retention settings in the customer tenant before relying on any signal.

4. Investigation checklist

Initial triage

- ☐ Capture the source signal: alert, risk detection, user report, unusual sign-in, or suspicious resource access.
- ☐ Preserve Microsoft Entra sign-in and audit evidence for users and service principals.
- ☐ Identify affected identities, applications, devices, IP addresses, locations, user agents, and resources accessed.

Token replay and access validation

- ☐ Determine whether sign-ins or resource access appear inconsistent with the user, device, location, or expected session context.
- ☐ Review MFA claims and authentication details alongside device, session, IP, application, and conditional access context.
- ☐ Identify whether the activity involves user tokens, service principal behavior, or both.

Cross-signal correlation

- ☐ Review Microsoft Entra sign-in logs, audit logs, user risk/service principal risk data, and Office sign-in/audit logs.
- ☐ Use advanced hunting, Unified Audit Log, SIEM/Sentinel, and Defender for Cloud Apps where connected.
- ☐ Check related mailbox, file, app, endpoint, and administrative activity after suspicious sign-ins.

Containment and remediation

- ☐ Revoke or invalidate affected sessions and tokens using tenant-approved procedures.
- ☐ Disable or block affected users/service principals if compromise is confirmed or active risk remains.
- ☐ Reset credentials, review MFA/security methods, and investigate affected devices or applications.
- ☐ Remove persistence mechanisms such as suspicious mailbox rules, app grants, device registrations, or administrative changes where found.

Closure and hardening

- ☐ Document evidence, timeline, impacted identities/resources, containment actions, and recovery outcomes.
- ☐ Update detections and SIEM/Sentinel rules for observed indicators and tactics.
- ☐ Review preventive controls such as risk-based Conditional Access, phishing-resistant authentication, token protection, CAE, and session controls as applicable.

5. Detailed investigation guidance

5.1 Confirm the likely token theft scenario

- Use the Microsoft Learn definition as the anchor: the attacker compromises and replays tokens issued to a user, even if MFA was already satisfied.
- Review sign-ins where authentication requirements appear satisfied but location, device, user agent, app, or resource access is inconsistent with expected behavior.
- Capture unusual identities, service principals, IP addresses, applications, resources, and timestamps in a single investigation tracker.

5.2 Build identity and service-principal scope

- Use Microsoft Entra sign-in and audit logs to identify user and service principal activity during the investigation window.
- Prioritize privileged users, high-value users, service principals, and identities with broad access to mail, files, data, cloud apps, or administrative functions.
- Where risk data is available, correlate RiskyUsers, UserRiskEvents, RiskyServicePrincipals, and ServicePrincipalRiskEvents with sign-in and audit activity.

5.3 Correlate downstream activity

- Use Unified Audit Log, Office sign-in/audit logs, Defender for Cloud Apps, advanced hunting, and SIEM/Sentinel data where configured.
- Check mailbox, file, SharePoint, Teams, app, endpoint, and administrative activity following suspicious sign-ins or token use.
- Document exactly which resources were accessed and whether sensitive data exposure can be confirmed, suspected, or not determined from available logs.

5.4 Contain active access

- Follow tenant-approved emergency access revocation guidance to invalidate sessions and reduce active attacker access.
- If active compromise is confirmed, use stronger containment such as disabling the affected account or service principal until remediation is complete.
- Investigate devices and endpoints associated with the stolen token scenario so the actor cannot simply regain access through the same path.

5.5 Recover and strengthen controls

- Reset credentials where compromise is suspected and review MFA/security methods for unauthorized additions or changes.
- Review app grants, service principal credentials, mailbox rules, forwarding, device registration, and administrative role changes for persistence.
- After containment, improve monitoring and access controls based on observed gaps, including SIEM/Sentinel ingestion, Defender for Cloud Apps connector coverage, Identity Protection alerts, Conditional Access, and token protection where appropriate.

6. Handy query and action starting points

Reminder

Validate command and query syntax against current Microsoft Learn docs and customer-approved procedures before running in a production tenant. Use least privilege and preserve evidence before destructive actions.

Use case	Example / location	Why it matters
Review user sign-ins	SignInLogs where UserPrincipalName =~ "<user@domain.com>"	Pivot on the affected identity across the investigation window.
Review service principal sign-ins	ServicePrincipalSignInLogs where ServicePrincipalId == "<service-principal-id>"	Pivot on suspicious service principal activity when available.
Review risk events	RiskyUsers / UserRiskEvents / RiskyServicePrincipals / ServicePrincipalRiskEvents	The playbook highlights exporting risk-related data for longer retention and investigation.
Review audit activity	AuditLogs where TargetResources has "<user-or-app-id>"	Correlate identity, device, app, and administrative changes.
Emergency access revocation	Use tenant-approved Microsoft Entra emergency access revocation procedures.	The playbook is focused on quick response to investigate, contain, and remediate token theft damage.

7. Evidence matrix

Question	Helpful evidence sources
Was token theft plausible?	Sign-in logs, authentication details, device/IP/location/user agent anomalies, MFA claim context
Which identities were affected?	Microsoft Entra user and service principal sign-in logs, audit logs, RiskyUsers, RiskyServicePrincipals
What resources were accessed?	Unified Audit Log, Office sign-in/audit logs, Defender for Cloud Apps, workload logs, advanced hunting
Was data accessed or exfiltrated?	Mailbox/file/app audit logs, Defender/Sentinel evidence, cloud app activity, endpoint evidence
Was persistence added?	Mailbox rules, forwarding, app grants, MFA method changes, device registrations, role changes
Was active access contained?	Session revocation evidence, account/service principal block state, risk remediation status, device containment status
What control gaps were found?	SIEM coverage, alerting configuration, risk detections, connector coverage, Conditional Access/session controls

8. Closure notes template

- ☐ Incident summary: suspected token theft source signal, affected identities, and resources at risk.
- ☐ Timeline: suspected token compromise/replay, suspicious sign-ins, resource access, discovery, containment, and recovery completion.
- ☐ Scope: users, service principals, devices, IP addresses, apps, resources, and telemetry sources reviewed.
- ☐ Evidence reviewed: Microsoft Entra sign-in/audit logs, risk data, Unified Audit Log, Defender for Cloud Apps, advanced hunting, SIEM/Sentinel, and resource logs.
- ☐ Verdict: confirmed token theft, suspected token theft, related identity compromise, benign, or inconclusive with rationale.
- ☐ Actions completed: sessions/tokens revoked, accounts/service principals blocked or restored, credentials reset, MFA/security methods reviewed, persistence removed, devices investigated.
- ☐ Follow-up recommendations: improve SIEM ingestion, alerts, Identity Protection policies, Conditional Access, token protection, CAE/session controls, and user/admin readiness.

9. Authoritative sources

Primary Microsoft Learn article: [Token theft playbook | Microsoft Learn](#)

Related Microsoft Learn playbook index: [Incident response playbooks | Microsoft Learn](#)

This field guide does not replace the official articles. Always reference Microsoft Learn for the latest decision tree, prerequisites, role details, portal paths, and product-specific guidance.